Presentation Outline:

- 1. INTRODUCTION
- 2. SCENARIO 1: CUSTOMER SENSITIVE INFORMATION.
- 3. SCENARIO 2: AI MODEL'S DATASETS.
- 4. KEY FINDINGS
- 5. RECOMMENDATIONS
- 6. Q&A

INTRODUCTION

This presentation aims to identify and analyze the key security risks ShopEZ may face when using its AI-driven customer analytics system. It helps the company better understand AI-related risks, recognize the most significant sources of potential loss, and support informed security decision-making.

Scope:
This presentation applies the FAIR model to evaluate potential security threats by analyzing their likelihood, severity, and associated financial and operational impacts. It focuses on two primary scenarios:

- **Scenario 1**: External attackers exploit model inversion techniques to gain unauthorized access to sensitive customer data.
- **Scenario 2**: External contractors with privileged access introduce risk, where vulnerabilities in third-party systems may compromise AI data integrity and reliability.

Both scenarios are supported by estimates of threat event frequency, system vulnerability, and Monte Carlo simulation results. These findings guide the selection of appropriate security and governance controls for AI systems.

SCENARIO 1 - OVERVIEW

- **Asset at Risk**: Customer Sensitive Information.
- **Threat Community**: External Malicious attackers.
- **Threat Type**: Malicious.
- **Threat Effect**: Confidentiality.
- **Threat Vector**: Model Inversion attack.
- **Scope statement**: Analyze the risk associated with **external malicious attackers** breaching the **confidentiality** of **customer sensitive information** accessible on the AI-Driven Customer analytics platform via **model inversion attack**.

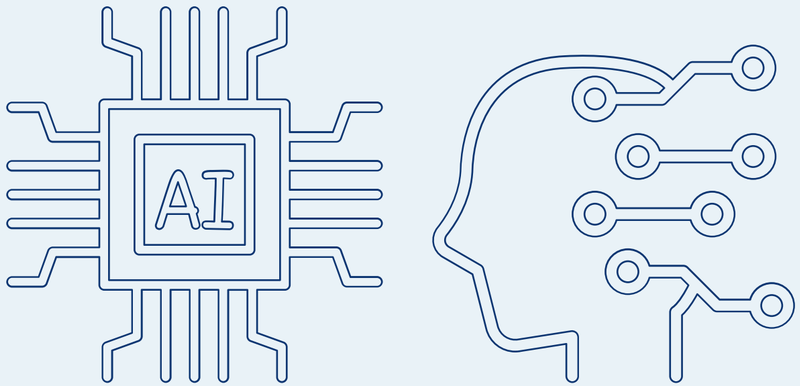
SCENARIO 1 - RISK ANALYSIS FINDINGS

1- THREAT EVENT FREQUENCY (TEF):

Threat Event Frequency							
Min	1	**ML**	3	**Max**	6	**Confidence level**	High
We have two sources for data: estimation provided by the information security and risk management department, which shows that over 24 months (about 2 years), six attempts of model inversion attacks occurred, which means in a year, the average could be 3 attempts, and the historical records show that six model inversion attack attempts occurred each year. That's why we concluded that TEF is [1,3,6] and chose high confidence.							

2- Vulnerability:

Vulnerability							
Min	20%	**ML**	50%	**Max**	60%	**Confidence level**	Medium
Medium confidence is reasonable because we have only one source of information (it is estimated that approximately half of the model's inversion attempts could potentially succeed in inferring sensitive information from the AI model).							



3- Secondary Loss Event Frequency (SLEF):

Secondary Loss Event Frequency							
Min	95%	**ML**	98%	**Max**	100%	**Confidence level**	Moderate
Because the breach involves sensitive customer data, we assigned high SLEF to reflect the significant confidentiality impact.							

4- Loss Magnitude estimates:

PRIMARY LOSSES:

Primary Response	Min	Ml	max	Confidence
Incident Response (Team Members*working hours*cost per hour) 8-10 people 40-60 hours €85/hour	8 people*40 hours*€85 cost per hour= €27,200	9 people*50 hours*€85 cost per hour= €38,250	10 people*60 hours*€85 cost per hour= €51,000	Moderate single data source
Forensic Investigation (Cost of an average forensic investigation is €60,000)	€50,000	€60,000	€70,000	Moderate single data source
Management Meetings (These sessions consistently involve eight participants and follow a fixed process, resulting in a stable internal labour cost of approximately €5,000 per incident)	€5,000	€5,000	€5,000	Moderate single data source
Employees Training Sessions	€3,000*1 = €3,000 (Assuming only one session conducted)	€3,000*3 = €9,000 (Assuming three sessions conducted)	€3,000*4 = €12,000 (Assuming four sessions conducted)	Moderate single data source
Total	€85,200	€112,250	€138,000	

Primary Replacement	Min	Ml	max	Confidence
Model cleanup and retraining	€150,000	€350,000	€500,000	Moderate single data source
Total	€150,000	€350,000	€500,000	

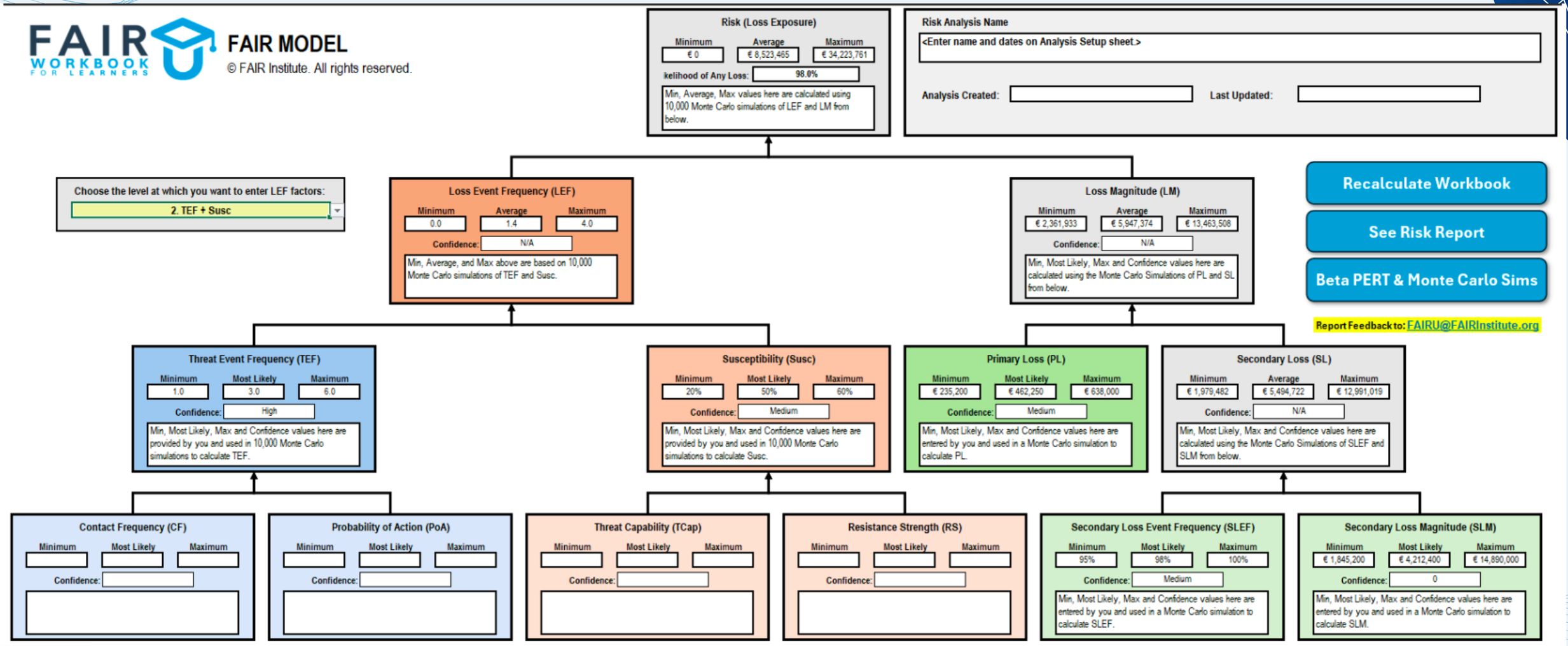
SECONDARY LOSSES:

Secondary Response	Min	Ml	max	Confidence
Customer notification (affected customer * €2 cost per customer)	2,000 customers * €2 = €4,000	49,000 customers * €2= €98,000	100,000 customers * €2 = €200,000	Moderate confidence single data source
Customer Support Calls (€3 per call) * (20% percentage of affected customers that will call) Assuming 20% of affected customers contact support = between 400 and 20,000 customers	400 customers * €3 = €1,200	9,800 customers * €3 = €29,400	20,000 customers * €3 = €60,000	Moderate confidence single data source
Credit monitoring (affected customer * €15 per subscription)	2,000 customers * €15 = €30,000	49,000 customers * €15 = €735,000	100,000 customers * €15 = €1,500,000	Moderate confidence single data source
Regulatory notification	€20,000	€40,000	€60,000	Moderate confidence single data source
Public relations activities	€40,000	€60,000	€70,000	Moderate confidence single data source
Total	€95,200	€962,400	€1,890,000	

Secondary Fines and Judgements	Min	Ml	max	Confidence
GDPR Fines The annual revenue of €500 million	Less than 10,000 customers = €250,000	Between 10,000 – 50,000 customers = €1 million	More than 50,000 customers = €10 million The 2% of the company's annual revenue = €10 million	Moderate due to uncertainty regarding how many data an attacker might compromise
Class action lawsuits	€1,500,000	€2,250,000	€3,000,000	Moderate confidence single data source
Total	€1,750,000	€3,250,000	€13,000,000	

SCENARIO 1 - RISK ANALYSIS FINDINGS

FAIR-U results



SCENARIO 1 - RISK ANALYSIS FINDINGS

FAIR-U results

Maximum:
€ 34,223,761

90th Percentile:
€ 14,993,775

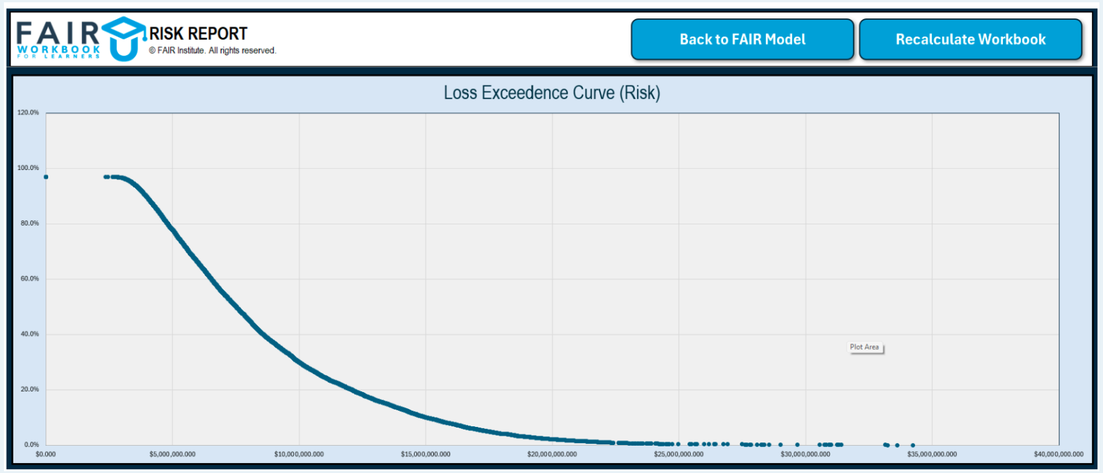
Average:
€ 8,523,465

10th Percentile:
€ 3,964,921

Minimum:
€ 0

Likelihood of Any Loss
98.5%

Likelihood of No Loss
1.5%



Interpretation of results:

- The FAIR analysis shows that the risk is recurring, with threat events expected 1-6 times per year and an average of 3 events annually, meaning it is an ongoing risk.
- System susceptibility is moderate (around 50%), indicating a significant chance of successful exploitation without additional controls.
- At least one loss-causing incident per year is likely, and secondary losses are almost certain (98%), including regulatory, legal, and reputational impacts.
- Secondary losses far exceed primary losses, with average indirect losses of €4.2 million per event, compared to average direct losses of €462,250.
- The average Annualized Loss Exposure (ALE) is approximately €8.5 million, classifying the risk as Major (Level 4) and representing a significant financial threat to the organization.

RECOMMENDED CONTROLS

To mitigate the risks associated with model inversion attacks, the following controls are recommended:

- Apply privacy-preserving techniques (e.g., limiting output detail) to reduce sensitive data inference.
- Enforce strict access control and query rate limiting to prevent excessive or malicious model interactions.
- Enhance monitoring and logging of model queries to enable early detection of abnormal inference attempts.
- Limit exposure of model outputs and explainability features to authorized users only.
- Establish AI-specific incident response procedures, including rapid containment and secure model retraining.
- Conduct regular security assessments and staff training focused on AI privacy and inference risks.
- Strengthen data governance and GDPR compliance controls to ensure accountability and regulatory readiness.

SCENARIO 2 - OVERVIEW

- **Asset at Risk**: AI model's datasets.
- **Threat Community**: External contractors with privileged access.
- **Threat Type**: Malicious.
- **Threat Effect**: Integrity.
- **Threat Vector**: Vulnerabilities in third-party integrations.
- **Scope statement**: Analyze the risk associated with **external contractors with privileged access** impacting the **integrity** of **AI model datasets** via **vulnerabilities** in **third-party integrations**.

SCENARIO 2 - RISK ANALYSIS FINDINGS

1- THREAT EVENT FREQUENCY (TEF):

Threat Event Frequency							
Min	2	**ML**	4	**Max**	6	**Confidence level**	High
Based on industry reports showing an average of 2 segmentation anomalies detected every 6 months (equivalent to 4 per year) and given that the company uses similar technologies and algorithms, this rate is considered representative of our environment. Therefore, TEF is estimated as [2, 4, 6] with high confidence							

2- Vulnerability:

Vulnerability							
Min	30%	**ML**	40%	**Max**	50%	**Confidence level**	Medium
Medium confidence is reasonable because this estimation was obtained from existing security controls.							

3- Secondary Loss Event Frequency (SLEF):

Secondary Loss Event Frequency							
Min	60%	**ML**	80%	**Max**	95%	**Confidence level**	Medium
The SLEF values were chosen based on the scenario and how it affects AI data. When this kind of issue happens, it usually leads to other impacts. Even though the values are high, the confidence is kept moderate because the estimate is based on one case study and not on detailed past data.							

4- Loss Magnitude estimates:

PRIMARY LOSSES:

Primary productivity	Min	Ml	max	Confidence
Lost revenue if the portal went down	€2,800,000 lost revenue per day*1 day= €2,800,000	€2,800,000 lost revenue per day*2 day= €5,600,000	€2,800,000 lost revenue per day*3 day= €8,400,000	Moderate confidence single data source
Total	€2,800,000	€5,600,000	€8,400,000	

Primary Response	Min	Ml	max	Confidence
Incident Response (Manpower) 10–12 people 40–60 hours €85/hour	10 people * (40 hours * €85/hour) = €34,000	11 people * (50 hours * €85/hour) = €46,750	12 people × (60 hours × €85/hour) = €61,200	Moderate confidence single data source
Forensic investigation (Cost of an average forensic investigation is €60,000)	€50,000	€60,000	€70,000	Moderate confidence single data source
Total	€84,000	€106,750	€131,200	

Primary Replacement	Min	Ml	max	Confidence
Retraining of the AI Model	€400,000	€500,000	€600,000	Moderate single data source
Total	€400,000	€500,000	€600,000	

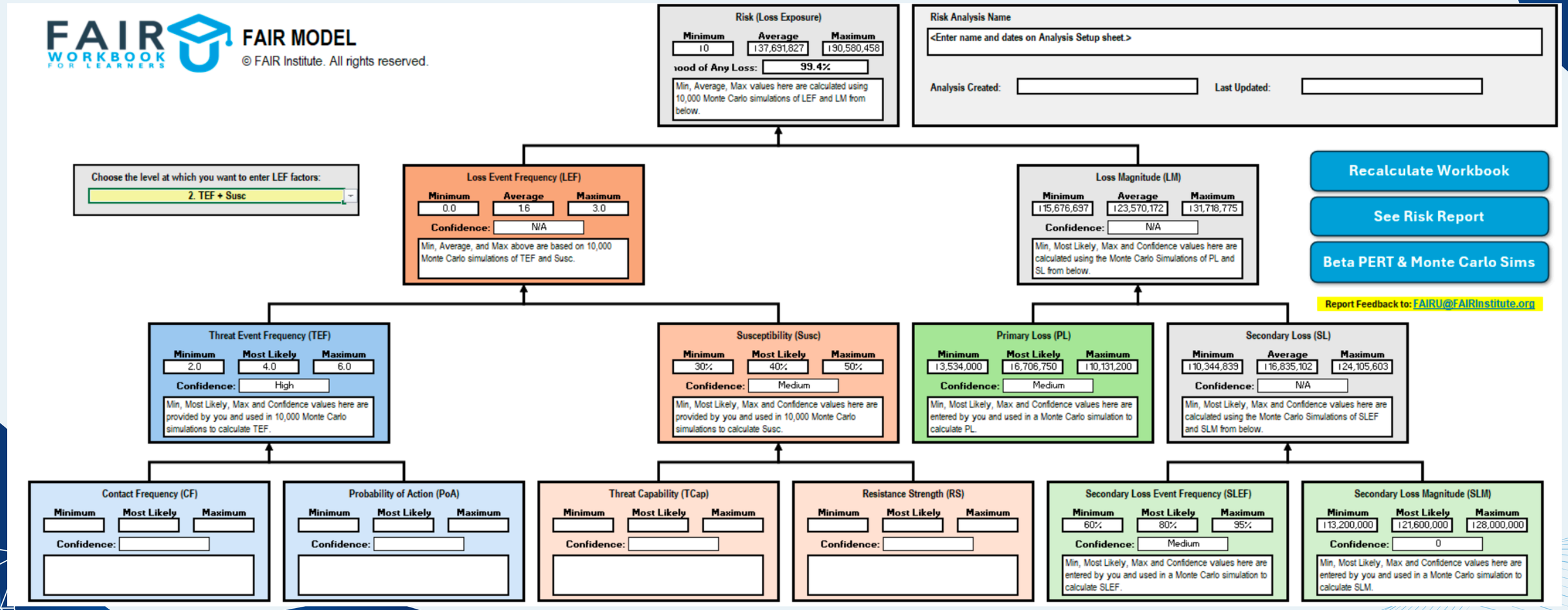
SECONDARY LOSSES:

Secondary Competitive Advantages	Min	Ml	max	Confidence
Loss of key differentiators based on the market	€1,200,000	€1,600,000	€2,000,000	Moderate confidence single data source
Customer trust impact (Customers switching to Competitor platforms)	€2 million	€5 million	€6 million	Moderate confidence single data source
Total	€3,200,000	€6,600,000	€8,000,000	

Secondary Fines and Judgements	Min	Ml	max	Confidence
GDPR Fines The annual revenue of €500 million between 2% to 4% of the company's annual revenue = €10 million to €20 million	The annual revenue * 2% = €500 million * 2% = €10 million	The annual revenue * 3% = €500 million * 3% = €15 million	The annual revenue * 4% = €500 million * 4% = €20 million	Moderate confidence single data source
Total	€10 million	€15 million	€20 million	

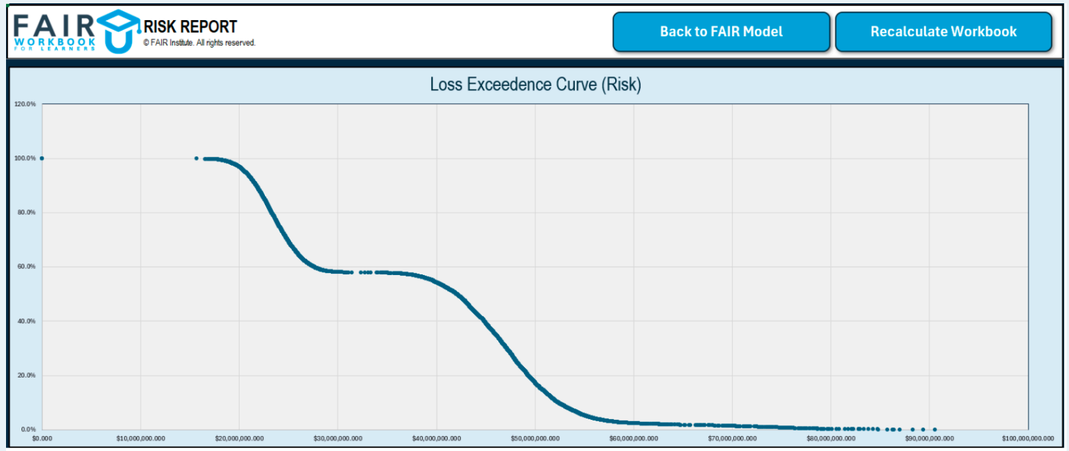
SCENARIO 2 - RISK ANALYSIS FINDINGS

FAIR-U results



SCENARIO 2 - RISK ANALYSIS FINDINGS

FAIR-U results



Maximum:
€ 90,580,458

90th Percentile:
€ 52,342,557

Average:
€ 37,691,827

10th Percentile:
€ 21,756,119

Minimum:
€ 0

Likelihood of Any Loss
99.9%

Likelihood of No Loss
0.1%

Interpretation of results:

- The FAIR analysis indicates a recurring threat, with 2-6 threat events per year and an average of 4 events annually, showing the risk is ongoing.
- System susceptibility is moderate (around 40%), meaning existing weaknesses could be exploited if controls are insufficient.
- An average of 1.6 loss events per year is expected, and secondary losses are highly likely (80%), including legal, regulatory, and reputational impacts.
- Secondary losses significantly exceeded primary losses, with average secondary losses of €21.6 million per event, compared to €6.7 million in direct losses.
- The average annualized loss exposure (ALE) is €37.69 million, classifying the risk as Critical (Level 5) and representing a severe financial threat to the organization.

RECOMMENDED CONTROLS

To mitigate the risks associated with adversarial data injection and corrupted data streams, the following controls are recommended:

- Strengthen data input validation and anomaly detection to prevent corrupted or manipulated data from entering AI pipelines, particularly from third-party data sources.
- Enhance continuous monitoring and logging of data streams and AI model behavior to detect segmentation anomalies and model drift at an early stage.
- Enforce role-based access control (RBAC) and segregation of duties to restrict access to training data, feature pipelines, and model configurations.
- Implement AI-specific incident response procedures, including isolation of compromised data and control model retraining.
- Conduct regular security assessments and penetration testing focused on AI data ingestion and model lifecycle risks.
- Provide staff awareness training for engineering, data science, and marketing teams on data poisoning and AI- related threats.

KEY FINDINGS

The FAIR analysis demonstrates that ShopEZ is exposed to material AI-related risks in both scenarios.

- **Scenario 1**: Reveals risks related to customer data confidentiality due to potential model inversion attacks.
- **Scenario 2**: Identifies risks to data integrity and system reliability arising from third-party access.

The results indicate a high probability of secondary impacts, including regulatory penalties and reputational damage. Although extreme losses are less frequent, the analysis shows they remain plausible.

These findings emphasize the importance of enhanced AI security, governance, and access controls.

CONCLUSION

The FAIR analysis shows that ShopEZ faces critical risks related to its AI customer analytics system. Both scenarios highlight weaknesses in access control, third-party integrations, and data protection that can lead to financial, operational, and reputational losses. While large losses are less frequent, moderate losses are highly likely, and successful incidents may trigger regulatory penalties and loss of customer trust. Strengthening AI security controls, monitoring, and governance is essential to reduce risk and ensure the reliability of the AI system.

Q&A

Thanks for your Attention,

Any questions?